

Vulnerability Scanning & Enumeration

Module 2 — Reconnaissance · Unit 09

You found the open doors in Unit 08. Now you find out *exactly* what's behind each one — and which are weak. Then you STOP at the plan.

Learning objectives

By the end of this unit you can:

- **Distinguish** scanning, enumeration, and vulnerability scanning.
- **Manually enumerate** HTTP, FTP, SMB, and SSH — and explain why manual still matters.
- **Run** targeted nmap **NSE scripts** and interpret the output.
- **Describe** automated vuln scanners (Nessus, OpenVAS) at an awareness level.
- **Map** a service/version to a **CVE** and read its **CVSS** severity.
- **Spot** likely **false positives** and verify them manually.
- **Turn** findings into a prioritized **attack plan** — without exploiting.
- **Produce** the Module 2 **Recon mini-project report**.

Three steps that build on each other

Step	Question it answers
Scanning (Unit 08)	"What's there?" — live hosts, open ports
Enumeration	"What <i>exactly</i> is it?" — users, shares, versions, config
Vuln scanning	"Which of these is <i>weak</i> ?" — match versions to known flaws

Each step digs deeper into the last. Today we go from "port 445 is open" to "here's the share, the user, and the CVE."

Why manual enumeration still matters

- Automated tools **miss context** and produce **false positives**.
- A human can spot a misconfiguration a scanner ignores.
- Manual enumeration finds **users and shares** a port scan never reveals.

Tools are fast; judgment is irreplaceable. Use both.

Ethics & Authorization

Enumeration and vuln scanning are ACTIVE — and louder than a port scan.

They send probes and sometimes **login attempts** to the target. **All of it requires authorization.**

Finding a vuln is NOT permission to exploit

- A scanner saying "*critical vulnerability*" is a **finding**, not a green light.
- Finding a weakness and attacking it are **completely different acts** — legally and ethically.
- Real, unauthorized finding? Follow **responsible disclosure** (Unit 01): don't post it, don't exploit it — report it to the owner.
- In this class everything stays on the **authorized lab target**, and we **stop at the plan**. Exploitation waits for Module 3.

Discussion: You scan a friend's site without asking and a tool reports a critical vuln. What are your legal and ethical obligations — and what must you absolutely NOT do?

Manual enumeration: HTTP

```
curl -I http://<target-ip>/          # server header  
curl http://<target-ip>/robots.txt   # disallowed paths
```

- Read the **server header** (e.g., Apache 2.2.8).
- Check **robots.txt** for paths someone tried to hide.
- Browse the site: look for apps, login pages, directory listings.

Web apps (DVWA, Mutillidae...) = a rich attack surface for Module 3.

Manual enumeration: FTP, SMB, SSH

```
ftp <target-ip>                # try anonymous login
smbclient -L //<target-ip>/ -N  # list SMB shares
enum4linux -a <target-ip>      # shares + users
nc <target-ip> 22              # SSH banner / version
```

- **FTP** — does anonymous login work? What files are visible?
- **SMB** — shares (`tmp`, `IPC$`) and **user accounts** (`msfadmin`).
- **SSH** — banner and version (e.g., `OpenSSH 4.7p1`).

This is the classic lesson: manual SMB enumeration finds users a port scan never could.

nmap NSE scripts

The **Nmap Scripting Engine** automates enumeration and detection.

```
nmap --script ftp-anon -p 21 <target-ip>  
nmap --script smb-os-discovery,smb-enum-shares -p 139,445 <target-ip>  
nmap --script vuln -p <ports> <target-ip>
```

- Script **categories**: `default`, `safe`, `vuln`.
- `ftp-anon` → "Anonymous FTP login allowed."
- `smb-enum-shares` → lists the shares.
- Compare NSE output to your **manual** findings — do they agree?

Automated vuln scanners (awareness)

Tool	Notes
Nessus Essentials	Free tier, registration-gated, IP-limited
OpenVAS / Greenbone	Free, fully open-source

- **Strength:** broad coverage, fast, lots of checks.
- **Weakness:** noisy, **false positives**, no human context.
- They flag *possible* vulnerabilities — a human still verifies.

Optional lab: run one, OR analyze the instructor's sample report.

Reading a CVE

- **CVE** = Common Vulnerabilities and Exposures — a public ID for one known flaw (e.g., `CVE-2011-2523`).
- **CVSS** = a 0–10 **severity score** (higher = worse).
- Map your **starred versions** from Unit 08 to their CVEs.

Examples (Metasploitable 2):

Service & version	CVE	What it is
vsftpd 2.3.4	CVE-2011-2523	Backdoor command execution (CVSS ~10)
Samba 3.x	CVE-2007-2447	"username map script" RCE
UnrealIRCd 3.2.8.1	CVE-2010-2075	Backdoor

11

False positives & the attack plan

- A **false positive** = a "vulnerability" that isn't real or exploitable.
- Scanners over-report — **verify manually** before trusting a finding.
- Turn *verified* findings into a prioritized **attack plan**:

Service & version	Port	CVE(s)	CVSS	True positive?	Why it matters
-------------------	------	--------	------	----------------	----------------

Plan only: "what would I try first, and why." **No exploitation.**

Key vocabulary

Term	Meaning
Enumeration	Digging into a service for users/shares/versions
Vulnerability scanning	Matching services to known weaknesses
Vulnerability	A weakness that could be exploited
SMB	Windows file/printer sharing (often enumerable)
NSE	Nmap Scripting Engine
CVE	Public ID for a specific known vulnerability
CVSS	0-10 severity score
False positive	A reported "vuln" that isn't real



Lab launch

Enumeration, Vuln Scanning & the Recon Mini-Project

Platform: Kali VM + **Metasploitable 2** on a **host-only** network. A TryHackMe **enumeration** room is an approved browser alternative. **Optional:** Nessus Essentials / OpenVAS.

Authorized target only. Confirm host-only networking and write your scope statement: *"I will enumerate and vuln-scan only the lab target. I will not exploit anything."*

Lab roadmap

- **A** — HTTP enumeration (`curl`, robots.txt, browse).
- **B** — FTP / SMB / SSH enumeration (`ftp`, `smbclient`, `enum4linux`, `nc`).
- **C** — nmap **NSE** scripts; compare to manual findings.
- **D** — *optional* automated vuln scan (Nessus/OpenVAS) or analyze the sample report.
- **E** — **CVE mapping** + prioritized **attack plan** (planning only).



This unit kicks off the **Module 2 Recon mini-project** — a graded report combining Units 07–09. Get the rubric **before** you start.

Recap

- **Scanning → enumeration → vuln scanning** — each digs deeper.
- Manual enumeration finds context (users, shares) tools miss.
- **NSE** scripts and automated scanners speed things up — but produce **false positives**.
- **CVE + CVSS** turn a version string into a measured risk.
- **Finding a vuln is not permission to exploit it.** We stop at the plan.
- Everything stays on the **authorized lab target**.

Exit ticket & discussion

Exit ticket: In one sentence each, define scanning, enumeration, and vuln scanning. Then: what is a false positive, and how would you verify one?

Discuss: A scanner flags a "critical" vuln on a server you don't own. What do you do — and what must you absolutely NOT do? Use *authorization* and *responsible disclosure*.

*Module 2 deliverable — the **Recon mini-project report**. Next: Module 3, Exploitation, on authorized targets only.*